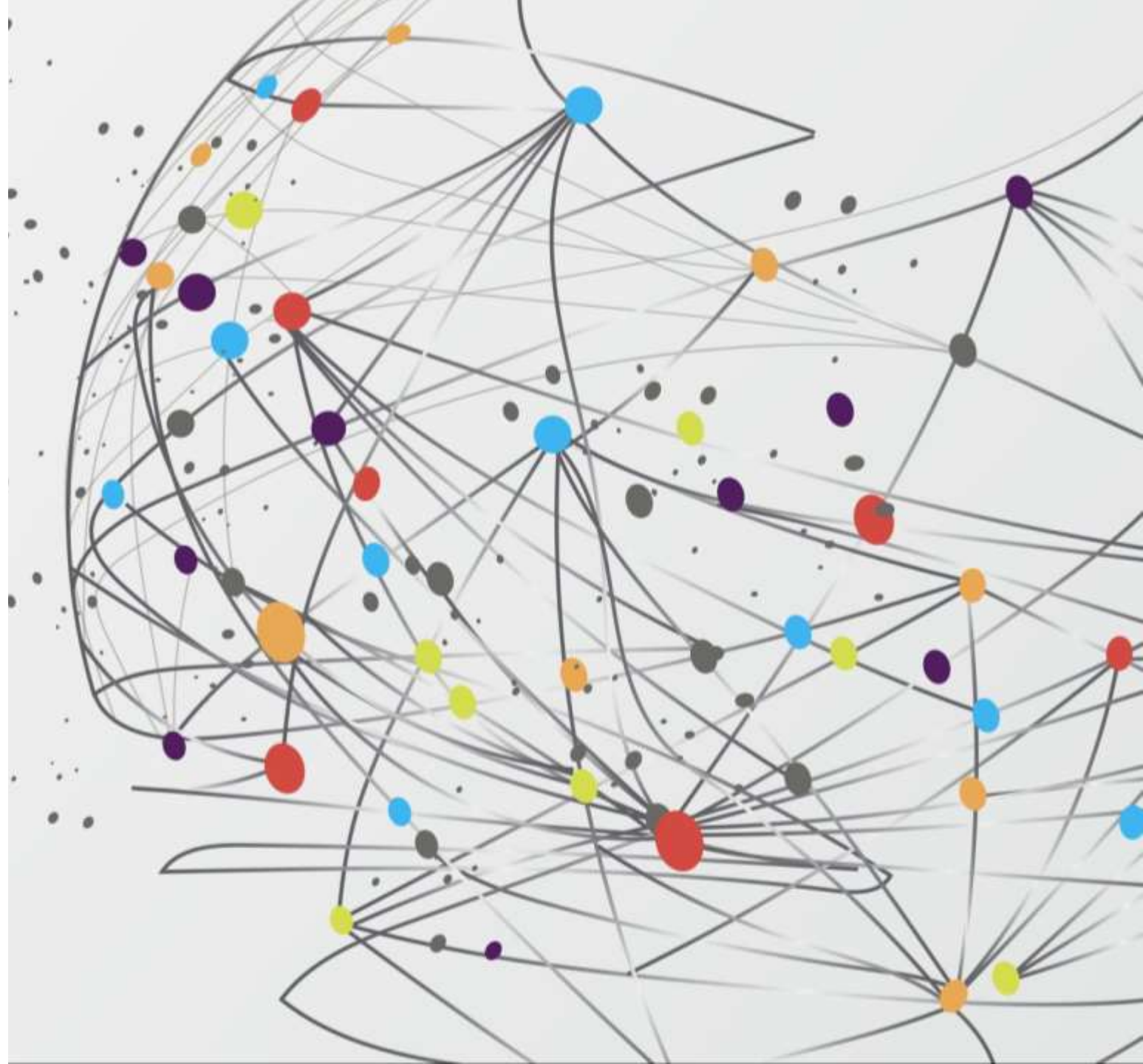

SİBER GÜVENLİĞE GİRİŞ

BÖLÜM 7 PASSWORD MANAGEMENT

Dr. Öğr. Üyesi Ahmet Kaşif
ahmet.kasif@btu.edu.tr



7.1 INTRODUCTION

7.1.1 THE PASSWORD PROBLEM

Statistics (from the Norton Report):

- 34% of people experienced losses due to password hacking in 2017.
 - Total cost: US\$172 billion.
 - Impacted 978 million people globally.
 - Average loss: US\$142 per user.
 - Average recovery time: 24 hours.
 - **Causes:** Virus infection, scam purchases, financial fraud, email phishing.
-

7.1.2 COMMON PASSWORD MISTAKES

Common Mistakes:

- Using the same password for multiple accounts (over 20%).
 - Sharing passwords with others (over 58% have done so at least once).
 - Reliance on weaker authentication methods (44% use fingerprints, 22% use patterns).
-

7.1.3 IGNORING PASSWORD BEST PRACTICES

Statistics:

- Over 70% of users do not follow standard password management recommendations.
 - Millennial users are even more likely to ignore guidelines.
 - **Impact:** Increased vulnerability to account hacking, personal information theft, and other cybercrimes.
-

7.1.4 THE IMPORTANCE OF PASSWORD MANAGEMENT

Verizon DBIR Report:

- Over 80% of data theft hacking activities are due to stolen or weak passwords.

Attack Vector:

- Stolen passwords are used in DDoS attacks via botnets.
 - **Impact:** DDoS attacks can overwhelm and disable websites.
-

7.1.5 THE IMPACT OF WEAK PASSWORDS

Consequences:

- Facilitate account theft.
 - Enable DDoS attacks.
 - Lead to various other cybercrimes.
 - **Call to Action:** Implement strong password management practices to mitigate these risks.
-

7.1.6 ELEMENTS OF CYBERSECURITY

Key Elements:

- Network Security (NS)
 - Information Security (IS)
 - Application Security (AS)
 - Business Continuity Planning (BCP)/Disaster Recovery
 - Leadership Commitment
 - Operational Security (OPSEC)
 - End-User Education
-

7.2 BASICS OF PASSWORDS

7.2.1 THE PURPOSE OF PASSWORDS

Basic Objective: To verify authority to access specific resources.

- **Historical Context:** The concept of passwords has evolved from ancient code words to modern digital security.

7.2.2 THE EVOLUTION OF PASSWORDS

Ancient Example: The "Shibboleth Event" in the biblical book of Judges, where pronunciation was used to identify enemies.

Traditional Era: Evolution from code words to physical keys and tokens.

- **Digital Era:** Introduction of digital passwords in 1961 at MIT with the CTSS project (UNIX-based).

7.2.3 MODERN PASSWORD USAGE

Usage:

- Restricting unauthorized access to computing devices (PCs, tablets, mobiles, routers, switches).
- Securing online digital services (internet-connected).
- **Evolution:** From simple codes to complex and sophisticated security measures.

7.2.4 TYPES OF MODERN PASSWORDS

Cost of Automation:

- Average cost of automated security system implementation: US\$2.88 million.

Impact on SMEs:

- High costs pose a significant challenge for small and medium-sized enterprises (SMEs).
-

7.2.5 PASSWORD LENGTH AND STRENGTH

Recommendations:

- SMEs should strictly follow standard practices from regulatory authorities and industry organizations.
- Compliance can significantly reduce the risk of major security breaches.

7.3 THREATS TO PASSWORDS

7.3.1 THE WEAKEST LINK: USER BEHAVIOR

Main Threat: User sluggishness and disregard for password management guidelines.

- **Consequences:** Increased risk of password theft, DDoS attacks, data breaches, and financial fraud.

7.3.2 COMMON WEAK PASSWORDS

Examples:

- 123456
 - 12345678
 - abc123
 - password
 - linkedin
-

7.3.3 COMMON TARGETS OF CYBERATTACKS

Common Targets:

- Data servers.
 - Application servers.
 - Storage servers.
 - Financial information.
 - Operational systems.
 - Computer networks.
-

Statistics (WatchGuard security survey Q2 2018):

- Over 1,700 Australian government and military employees used "123456."
 - 544 used "password," 405 used "linkedin," and 120 used "12345678."
 - **Impact:** These passwords are easily cracked and often blacklisted.
-

7.3.4 TYPES OF PASSWORD THREATS

Threats:

- **Eavesdropping:** Intercepting passwords during entry.
 - **Guessing:** Trying common or personal information.
 - **Cracking software:** Using tools to guess passwords.
 - **Offline hash cracking:** Stealing and cracking password hashes.
 - **Password recovery/reset attacks:** Exploiting recovery processes.
-

-
- **Same password across accounts:** Compromising one account leads to others.
 - **Default passwords:** Using factory-set passwords.
 - **Malicious software:** Sniffers and keyloggers.
 - **Backdoor exploits:** Gaining unauthorized access.
 - **Malicious plugins:** Compromised browser extensions.
 - **Phishing:** Tricking users into revealing passwords.
-

7.3.5 MITIGATING PASSWORD THREATS

Solutions:

- Adhere to standard password management guidelines.
 - Use recommended security software.
 - Employ strong, unique passwords for each account.
 - Utilize multi-factor authentication (MFA) where available.
 - Regularly update passwords.
-

-
- Avoid default passwords.
 - Be cautious of phishing attempts.
 - Use a reputable password manager.
 - Keep software and systems updated.

7.4 GOOD AND BAD ABOUT PASSWORDS

7.4.1 THE PASSWORD DILEMMA

Problem: People prefer easy-to-remember passwords, compromising security.

Goal: Understanding the characteristics of good and bad passwords is crucial for effective security.

7.4.2 CHARACTERISTICS OF GOOD PASSWORDS

Features of Good Passwords:

- **Length:** 10-15 characters minimum.
 - **No Plain Text:** Avoid easily guessable words or phrases.
 - **Case Variation:** Use a mix of lowercase and uppercase letters.
 - **Special Characters:** Include symbols (@, #, \$, %, etc.) randomly.
-

-
- Numbers:** Incorporate numbers at different positions.
 - No Personal Information:** Avoid names, birthdays, etc.
 - No Sharing:** Never share passwords with others.
 - Pattern Variation:** Avoid predictable patterns.
 - Regular Changes:** Change passwords frequently.
-

7.4.3 CHARACTERISTICS OF BAD PASSWORDS

Features of Bad Passwords:

- **Plain Text:** Easily guessable words.
 - **Short Length:** Too few characters.
 - **Lack of Variety:** No mix of character types.
 - **No Case Variation:** Only lowercase or uppercase.
 - **Reused Passwords:** Same password across multiple accounts.
 - **Meaningful Words:** Dictionary words or common phrases.
-

-
- Simple Modifications:** Adding a single digit (e.g., mango1).
 - Repeated Words:** Using the same word twice (e.g., fishfish1).
 - Reversed Words:** Using a word backward (e.g., elppa for apple).
 - Character Substitution:** Using numbers for letters (e.g., z3r0).
 - Related to User Info:** Using usernames or account names.
-

7.4.4 THE RISKS OF BAD PASSWORDS

Impact:

- Increased vulnerability to hacking.
 - Potential for data breaches and financial losses.
 - Compromised accounts can be used for malicious activities.
 - **Call to Action:** Avoid all bad password practices to enhance security.
-

7.5 HOW DO BAD GUYS HACK YOUR PASSWORD?

7.5.1 THE HACKER'S ARSENAL

Introduction: Hackers are skilled and creative, constantly developing new strategies to compromise accounts.

- **Goal:** Understanding these techniques is crucial for effective password protection.

7.5.2 OVER-THE-SHOULDER TECHNIQUE

Method: Stealing passwords by watching users type them in or observing written passwords.

Vulnerabilities: Public places, shared workspaces, carelessness with written passwords.

- **Mitigation:** Be aware of your surroundings, use privacy screens, avoid writing down passwords.

7.5.3 DICTIONARY HACKING TECHNIQUE

Method: Using word lists and variations to guess passwords.

Effectiveness: Effective against passwords based on common words or phrases.

- **Mitigation:** Avoid dictionary words, use strong and complex passwords.

7.5.4 PASSWORD GUESSING TECHNIQUE

Method: Guessing passwords based on user psychology, gender, background, etc.

Vulnerabilities: Predictable personal information, common patterns.

Example: Women often use names of loved ones as passwords.

- **Mitigation:** Avoid using personal information in passwords.

7.5.5 BRUTE-FORCE ATTACK TECHNIQUE

Method: Trying all possible combinations of characters to crack passwords.

Effectiveness: Highly effective against short or simple passwords.

Speed: Modern computers can try thousands of combinations per second.

- **Mitigation:** Use long and complex passwords, implement account lockout policies.

7.5.6 THE HACKER'S CREATIVITY

Challenge: Hackers use out-of-the-box thinking and advanced techniques.

Importance: Constant vigilance and strong password practices are essential.

- **Call to Action:** Prioritize password security and stay informed about emerging threats.

7.6 EFFECTIVE PASSWORD MANAGEMENT TIPS

7.6.1 THE IMPORTANCE OF PASSWORD MANAGEMENT

Definition: Password management involves procedures and activities to maintain password security.

- **Context:** Increasing identity theft underscores the need for robust password management.

Statistics:

- 6.64% of online consumers experienced identity theft in 2017 (1 in 15 users).
 - Identity theft increased by over 1 million cases in 2017 compared to 2016.
 - One identity theft incident every 2 seconds.
 - 3 billion passwords stolen or compromised in 2016 (Credential Spill Report 2017).
 - Stolen passwords used in 90% of login attempt traffic.
-

7.6.2 ESSENTIAL PASSWORD MANAGEMENT PRACTICES

Practices:

- **Length:** Use passwords of 12-20+ characters.
 - **Privacy:** Never share passwords with anyone.
 - **Uniqueness:** Use different passwords for each account.
 - **No Written Records:** Avoid writing down or copying passwords.
 - **No Saved Files:** Do not save passwords on your computer.
 - **Regular Changes:** Change passwords every 3-4 months.
-

-
- Pattern Variety:** Use different patterns for each password.
 - Avoid Simple Endings:** Do not use single numbers at the end.
 - Biometrics:** Use biometric passwords when available.
 - Two-Factor Authentication (2FA):** Enable 2FA.
 - Multi-Factor Authentication (MFA):** Enable MFA.
-

-
- Encryption:** Encrypt files containing password information.
 - Browser Security:** Do not save critical passwords in browsers.
 - Password Managers:** Use reputable password managers.
 - Typing Speed:** Type passwords quickly to prevent observation.
 - Memorization:** Memorize passwords instead of relying on notes.
 - Password Generators:** Use software to generate strong passwords.
-

-
- No Reuse:** Avoid reusing old passwords.
 - Email Security:** Do not send or save passwords in emails.
 - Awareness:** Be aware of surroundings when entering passwords.
 - Memorability:** Choose strong passwords that are easy for you to remember.
-

7.6.3 THE IMPACT OF EFFECTIVE MANAGEMENT

Benefits:

- Enhanced protection against identity theft.
 - Reduced risk of account compromise.
 - Improved overall cybersecurity.
 - **Call to Action:** Implement these practices to effectively and efficiently manage your passwords
-

7.7 CREATING AND MANAGING SECURE PASSWORDS

7.7.1 THE IMPORTANCE OF STRONG PASSWORDS

Context: Our lives depend heavily on computers, the internet, and online services.

Importance: Passwords control access to personal, business, and social information.

Risk: Compromised passwords lead to data breaches, privacy violations, and loss of digital assets.

Threat: Hackers use sophisticated techniques to steal passwords.

- **Solution:** Strong passwords and complementary security measures.

7.7.2 CREATING STRONG PASSWORDS

Qualities of Strong Passwords:

- Non-guessable
 - Longer length
 - Complex pattern of characters
 - Complex combination of characters
 - Out-of-the-box ideas
 - Not based on personal information
 - Better password management
-

Example:

- Expression: "I get bored with a government job"
- Password: "Ig3b0W@gV!"
- Techniques: Character substitution, random capitalization.

7.7.3 BIOMETRIC AUTHENTICATION

Biometrics:

- Fingerprints (unique and reliable)
- Facial recognition (growing in importance)
- Emerging technologies: walking patterns, body gestures, vein patterns

Applications:

- Devices (computers, tablets, mobiles)
 - Applications (mobile, desktop, online tracking)
 - Government (passports, immigration)
 - Security-sensitive areas (airports, malls, military installations)
-

Benefits:

- Increased security and reliability
- Potential to prevent terrorist activities

Concerns:

- Privacy issues (data access in public places)
-

7.7.4 TWO-FACTOR AUTHENTICATION (2FA)

2FA:

- Also known as dual-factor or two-step authentication
 - Requires a second form of verification (passcode)
 - Passcode delivery methods: text message, automated call, email, web links
 - Passcode characteristics: auto-generated, one-time use, time-sensitive
-

Factors:

- Possession factor (something you have)
 - Inheritance factor (something you are)
 - Knowledge factor (something you know)
 - Location factor
 - Time factor
 - Hardware tokens
-

Benefits:

- Enhanced security and reduced risk of compromise

Implementation:

- Add phone number to the server
 - Choose passcode delivery method
 - Verify test code
-

7.8 MULTI-FACTOR AUTHENTICATION (MFA)

MFA:

- Uses three or more factors
- Addresses vulnerabilities in 2FA

Three Major Factors:

- What you know (knowledge factors: password, PIN)
 - What you are (inherence factors: biometrics, facial recognition)
 - What you have (possession factors: key fob, mobile device)
-

Emerging Factor:

- Location-based authentication

Benefits:

- Superior security for critical data
-

7.9 ONE-TIME PASSWORDS (OTP)

OTP:

- Dynamic passwords: created, used, and discarded
- Used for a single transaction or session
- Example: One-time PINs (OPINs) in online banking

Benefits:

- Cannot be reused for cyberattacks
- Difficult to intercept

Applications:

- Financial systems (banks, insurance)
 - Mission-critical systems
-

7.10 PASSWORD MANAGERS

Problem:

- Users struggle to create and remember many strong passwords.
- Reusing weak passwords is a major security risk.

Solution:

- Password manager software
 - Generates and stores encrypted passwords
-

Features:

- Master password
- Local or cloud storage
- Cross-platform compatibility (good password managers)

Drawbacks of Browser Password Managers:

- Often store passwords in plain text
 - Limited cross-platform support
-

7.11 THE POWER OF PASSWORD MANAGERS

Benefits:

- Generating strong passwords
 - Eliminating the need to remember multiple passwords
 - Protection against password theft
 - Encrypted storage of passwords
 - Local and cloud storage options
 - Easy access to passwords
-

Encryption:

- Use a password manager with strong encryption (at least 256-bit).

Recommendation:

- Security experts recommend using password managers.
-

7.12 PASSWORD MANAGER TOOLS

7.12.1 INTRODUCTION TO PASSWORD MANAGERS

Importance:

- Vital for modern computer and data security.
- Many options available; choose based on features, capabilities, and security.

Security Considerations:

- Follow security guidelines and recommendations.
- In the US, the NSA provides guidelines for critical data security.

Focus:

- Overview of the top five password manager tools.
-

7.12.2 DASHLANE

Features:

- Free and paid versions
 - Free version supports up to 50 passwords
 - Strong encryption protocols (AES-256)
 - Multi-browser support (Firefox, Chrome, Internet Explorer)
 - Mobile wallet and payment gateway protection
-

-
- Auto-fill and auto-login
 - Secure password storage and transmission
 - Strong password generator
 - Multiple passwords on the same website
 - Web access from anywhere
-

-
- Platform support (Android, iOS, PC, Mac)
 - Local and cloud storage
 - One-click password change
 - Password migration
 - Password categorization
 - Intuitive web interface
-

-
- Support for Chrome OS, MS Edge, and Linux
 - Two-factor authentication
 - Credit monitoring and data backup
 - Identity theft insurance and restoration help
 - Dark web alerts
 - Password group sharing (business users)
 - Secure storage of personal information, IDs, receipts, and payments
 - Zero-knowledge architecture
-

Plans:

- Free, monthly, annual, and business plans

7.12.3 LASTPASS

Features:

- Free and paid versions
 - Multiple user segments
 - Secure password vaults
 - Multi-platform support (Android, iOS, Mac, PC, Windows)
 - Smooth password access across devices
 - Auto-fill and saving options
-

-
- Strong password generation
 - Authenticator feature
 - Multi-factor authentication
 - Secure notes
 - Secure sharing
 - Data file storage (up to 1 GB)
-

-
- Emergency access
 - Cloud-based service
 - TRUSTe certified for privacy
 - Browser support
 - Support for Chrome OS and Linux
 - Master password reset options
 - Intuitive interface
 - Password strength alerts and scores
-

-
- Automatic password change
 - Username generation
 - Zero-knowledge standard
 - Auto-fill shopping forms
 - Secure storage of credit card information, personal information, payment wallets, and Wi-Fi information
 - Good customer support

Plans:

- Personal and enterprise categories
-

7.13 ZOHO VAULT

Features:

- Part of ZOHOO's cloud service suite
 - Free and paid plans
 - AES-256 encryption
 - Zero-knowledge architecture
 - Secure password sharing within groups
 - Auto-login
-

-
- User roles and levels
 - Single logout
 - Password import and export
 - Centralized password management
 - Access from anywhere
 - Multi-platform support (Windows, Linux, Android, Mac, iOS, Chrome OS)
 - Two-factor authentication
-

-
- Lightweight (cloud and browser plugins)
 - Secure storage of personal information, social security numbers, passports, and credit card information
 - Auto form-filling
 - Password chambers for security levels
 - Password sharing with external users (link and secret key)
 - SSL connection
-

Benefits:

- Integration with other ZOHO services
 - Affordable pricing
-

7.14 KEEPPASS

Features:

- Open-source (GNU license)
 - Free
 - Multi-platform (Windows, Linux, Mac, iOS, Android)
 - Local and online data storage
 - Password categorization (folders)
 - Portable storage support
 - Password strength check and alerts
-

-
- Password import and export
 - Data editing
 - Strong encryption (AES-256 and Twofish)
 - Password generation
 - Advanced security features
 - Keylogger protection
-

-
- SHA-256 for master key hashing
 - Brute-force attack resistance
 - Full control over source code
 - Simple and intuitive interface
 - Customizable
 - Local data storage
-

-
- Multiple file support for import and export
 - Global auto-type hotkeys
 - Drag-and-drop capability
 - Plugin-based architecture
 - Available in over 40 languages
-

Drawbacks:

- No automated username/password entry (manual entry required)

7.15 ROBOFORM

Features:

- Multiple plans
 - Personal and enterprise users
 - Rich feature set
 - Secure storage of personal information, credit card information, passwords, contacts, identities, notes, and other critical information
 - Browser bookmark synchronization
 - Cross-platform compatibility
-

-
- Mobile apps
 - Cloud and local storage
 - AES-256-bit encryption with PBKDF2 SHA-256 protocol
 - One-click form filling
 - Auto-fill for personal and billing information
 - Secure sharing of login information via email
 - Strong password generator
 - Single-click password saving
-

-
- Free subscription (limited features)
 - One-click database synchronization
 - Manual and automatic password entry
 - Account data backup
 - Access from anywhere, anytime
 - Powerful password and personal information management
-

-
- Easy and fast installation
 - Browser extensions
 - Password import and export
 - Two-factor authentication
 - Emergency access
 - Web and window app password support
-

-
- Safe notes for secure storage
 - User-friendly interface
 - Zero-knowledge architecture
 - Good customer support
-